

业务逻辑及越权漏洞报告

测试目标：Flask 用户管理系统（个人中心 + 充值功能）

测试日期：2026-07-09

漏洞数量：9 个

漏洞列表

#	漏洞名称	风险等级
1	无需登录访问个人中心	高危
2	水平越权查看他人资料	高危
3	水平越权给他人充值	高危
4	垂直越权（普通用户查看管理员）	高危
5	负金额充值套现	高危
6	余额无下限可透支	中危
7	充值无上限	中危
8	用户 ID 可枚举	中危
9	双扩展名上传绕过	中危

漏洞 1：无需登录访问个人中心

URL： GET /profile?user_id=xxx

测试：

```
curl "http://.../profile?user_id=admin"
```

无需携带任何会话凭证即可查看任意用户资料。

风险：未认证用户可批量抓取所有用户个人信息。

漏洞 2：水平越权查看他人资料

URL： GET /profile?user_id=xxx

测试：admin 登录后修改 user_id 为 alice

```
curl -b cookies.txt "http://.../profile?user_id=alice"
```

风险：任意登录用户可查看其他用户的邮箱、手机、余额。

漏洞 3：水平越权给他人充值

URL： POST /recharge

测试：admin 登录后修改 user_id 为 alice

```
curl -X POST -b cookies.txt -d "user_id=alice&amount=9999" "http://.../recharge"
```

风险：任意登录用户可操作其他用户的余额。

漏洞 4：垂直越权

测试：注册普通用户后查看 admin 资料

```
curl -b user_cookies.txt "http://.../profile?user_id=admin"
```

风险：低权限用户可查看高权限用户资料，权限分级完全失效。

漏洞 5：负金额充值套现

URL： POST /recharge

测试：

```
curl -X POST -d "user_id=admin&amount=-50000" "http://.../recharge"
```

风险：攻击者可通过负金额充值恶意扣减任意用户余额。

漏洞 6：余额无下限

充值负金额后余额变为负数，系统无最低余额限制，可无限透支。

漏洞 7：充值无上限

充值金额无上限限制，传入超大数值可导致金额异常。

测试：

```
amount=9999999999999999
```

漏洞 8：用户 ID 可枚举

遍历 user_id 参数可探测系统中是否存在该用户。

测试：

```
curl "http://.../profile?user_id=1"    # 用户存在
curl "http://.../profile?user_id=99"   # 用户不存在
```

漏洞 9：双扩展名上传绕过

上传 test.php.png 可通过扩展名检查，由于仅判断最后一个扩展名。

测试：

```
curl -X POST -F "file=@shell.php.png" "http://.../upload"
```

修复状态

#	漏洞	状态
1	无需登录访问个人中心	✓ 已修复
2	水平越权查看他人资料	✓ 已修复
3	水平越权给他人充值	✓ 已修复
4	垂直越权	✓ 已修复
5	负金额充值套现	✓ 已修复
6	余额无下限	✓ 已修复
7	充值无上限	✓ 已修复
8	用户 ID 可枚举	✓ 已修复
9	双扩展名上传绕过	✓ 已修复